

**Instituto Tecnológico y de Estudios Superiores de Monterrey
Campus Monterrey**

Escuela de Ingeniería y Ciencias

Ingeniería en Ciencias de Datos y Matemáticas

Uso de álgebras modernas para seguridad y criptografía, MA2006B.604

Manual del usuario - Etapa 1: Gestor de Identidades

Equipo 2:

Ana Lidia Hernández Díaz	A00838643
Ana Paula García Valverde	A01174572
María Fernanda Montoya López	A01743214
Javier Rojas Orrante	A01352213
Xavier Lago Hicks	A01403177

Profesores:

Raúl Gómez
Anas Wajid
Alberto F. Martínez

Proyecto: Firmas Solidarias – Tecnología Criptográfica para los Derechos Humanos

Socio Formador: Casa Monarca

Monterrey, Nuevo León. 30 de abril de 2026

Índice

1. Introducción	1
1.1. ¿Qué es la aplicación?	1
1.2. ¿Para qué sirve?	1
1.3. ¿A quién va dirigida?	1
2. Requerimientos del Sistema	2
2.1. Hardware mínimo	2
2.2. Software necesario	2
2.2.1. Navegadores compatibles (clientes)	3
2.3. Versiones compatibles y dependencias del proyecto	3
3. Instalación	3
3.1. Opción A: Instalación local (desarrollo)	3
3.2. Opción B: Instalación con Docker	4
3.3. Opción C: Despliegue en Render (producción)	4
4. Inicio de la Aplicación	5
4.1. Cómo acceder	5
4.2. Inicio de sesión	5
4.2.1. Login por contraseña (Operativo / Voluntario)	5
4.2.2. Login criptográfico (Administrador / Coordinador)	5
4.2.3. Credenciales de demostración	6
4.3. Configuración inicial	6
5. Guía de Uso	7
5.1. Crear un nuevo usuario (Administrador)	7
5.2. Activar un usuario pendiente (Administrador)	8
5.3. Revocar un usuario (Administrador)	9
5.4. Emitir credenciales criptográficas (Administrador)	9
5.5. Descargar archivos criptográficos	10
5.5.1. Descargar el archivo de acceso (private_key.pem)	10
5.5.2. Descargar el certificado (certificate.pem)	11
5.6. Registrar un beneficiario	11
5.7. Cambiar el estado de un beneficiario (Coordinador / Administrador)	12
5.8. Generar reportes en PDF	13
5.9. Cambiar el rol de un usuario (Administrador)	13

5.10.Desbloquear una cuenta bloqueada (Administrador)	14
5.11.Activar el administrador espejo (recuperación de emergencia)	15
5.12.Auto-registro de voluntarios	16
5.13.Consultar la auditoría (Administrador)	17
5.14.Ver certificados digitales	18
5.14.1. Certificado de la autoridad firmante (CA)	18
5.14.2. Certificado de un usuario	18
6. Solución de Problemas	19
6.1. Errores comunes	19
6.2. Qué hacer si algo falla	20
6.3. Contacto de soporte	20
7. Preguntas Frecuentes (FAQ)	20
8. Referencias	21

Índice de cuadros

1.	Usuarios objetivo del sistema y sus características de acceso	2
2.	Requerimientos mínimos de hardware para el servidor	2
3.	Software requerido para la instalación del servidor	2
4.	Navegadores web compatibles para los usuarios finales	3
5.	Dependencias del proyecto definidas en <code>pyproject.toml</code>	3
6.	Credenciales de demostración disponibles	6
7.	Tipos de reporte disponibles para exportación	13
8.	Errores comunes y sus soluciones	19

Índice de figuras

1.	Formulario de creación de usuario en el panel de administración	8
2.	Vista de reportes	13
3.	Cambio de rol de usuario	14
4.	Activación de cuenta bloqueada	15
5.	Descarga de certificado	19

1. Introducción

1.1 ¿Qué es la aplicación?

El Gestor de Identidades es una aplicación web desarrollada para Casa Monarca. Su propósito es administrar de manera segura las identidades digitales del personal de la organización: quién puede acceder al sistema, qué puede hacer y con qué nivel de confianza criptográfica.

El sistema implementa una Infraestructura de Clave Pública (PKI) interna que emite certificados digitales X.509 para los roles de mayor privilegio, mientras que los roles operativos acceden con credenciales tradicionales (correo electrónico y contraseña).

La aplicación está construida con Python 3.11+, el framework web FastAPI, el ORM SQLAlchemy y la biblioteca de criptografía cryptography de Python. Puede ejecutarse localmente con SQLite o desplegarse en producción con PostgreSQL y Docker.

1.2 ¿Para qué sirve?

La aplicación resuelve las siguientes necesidades operativas y de seguridad de Casa Monarca:

1. Gestión de usuarios: Crear, activar, revocar y expirar cuentas del personal con control granular por rol.
2. Control de acceso basado en roles (RBAC): Cuatro niveles de permisos jerárquicos que limitan qué puede hacer cada tipo de usuario en el sistema.
3. Autenticación criptográfica: Los roles privilegiados (Administrador y Coordinador) se autentican mediante archivos criptográficos (`private_key.pem` + `certificate.pem` + contraseña), proporcionando autenticación de dos factores.
4. Emisión de certificados digitales: Generación de certificados X.509 firmados con RSA-2048 y SHA-256, siguiendo una cadena de confianza verificable.
5. Registro de beneficiarios: Sistema CRUD para el seguimiento de personas migrantes atendidas por la organización, organizado por áreas (Legal, Psicosocial, Humanitario, Administración, Comunicación).
6. Auditoría completa: Registro inmutable de todas las acciones realizadas en el sistema, incluyendo inicios de sesión, cambios de estado, emisión de certificados y accesos denegados.
7. Recuperación de emergencia: Mecanismo de administrador espejo (backup) que garantiza la continuidad operativa si el administrador principal pierde acceso.
8. Generación de reportes: Exportación de datos en PDF con hash de integridad SHA-256 embebido para detectar manipulaciones.

1.3 ¿A quién va dirigida?

La aplicación está diseñada para el personal de Casa Monarca, dividido en cuatro roles funcionales:

Cuadro 1: Usuarios objetivo del sistema y sus características de acceso

Rol	Método de acceso	Descripción y capacidades
Administrador	Archivos criptográficos	Director de TI o encargado de seguridad. Control total: gestión de usuarios, emisión de certificados, auditoría, recuperación de emergencia.
Coordinador	Archivos criptográficos	Coordinadores de área (Legal, Psicosocial, Humanitario, etc.). Gestión de beneficiarios de su área, visualización de documentos y operaciones.
Operativo	Correo + contraseña	Personal operativo de campo. Registro de beneficiarios, consulta de documentos y operaciones.
Voluntario	Correo + contraseña	Voluntarios y pasantes. Acceso limitado a consulta de documentos y registro básico de beneficiarios.

2. Requerimientos del Sistema

2.1 Hardware mínimo

Cuadro 2: Requerimientos mínimos de hardware para el servidor

Componente	Requisito mínimo
Procesador	Intel Core i3 / AMD Ryzen 3 o superior (arquitectura x86_64)
Memoria RAM	2 GB mínimo (4 GB recomendado para uso concurrente)
Disco duro	500 MB de espacio libre (sin contar la base de datos)
Red	Conexión a Internet para despliegue remoto, o red local para acceso interno

Nota sobre clientes

Para acceder como usuario desde un navegador, cualquier computadora, tableta o teléfono moderno es suficiente. Los requerimientos de hardware de esta tabla aplican únicamente al servidor donde se instala y ejecuta la aplicación.

2.2 Software necesario

Cuadro 3: Software requerido para la instalación del servidor

Software	Versión mínima	Propósito
Python	3.11+	Lenguaje de ejecución del servidor
pip	23.0+	Gestor de paquetes de Python
Git	2.30+	Clonar el repositorio del proyecto
Docker (opc.)	20.0+	Despliegue alternativo con contenedores
PostgreSQL (opc.)	14+	Base de datos recomendada para producción

2.2.1 Navegadores compatibles (clientes)

Cuadro 4: Navegadores web compatibles para los usuarios finales

Navegador	Versión mínima	Notas
Google Chrome	90+	Recomendado
Mozilla Firefox	88+	Compatible
Microsoft Edge	90+	Compatible
Safari	14+	Compatible (macOS/iOS)

2.3 Versiones compatibles y dependencias del proyecto

Cuadro 5: Dependencias del proyecto definidas en `pyproject.toml`

Paquete	Versión	Función en el sistema
fastapi	≥ 0.115.0	Framework web asíncrono para las rutas HTTP
cryptography	≥ 43.0.0	RSA, X.509, firmas digitales, cifrado de llaves
itsdangerous	≥ 2.2.0	Firmado HMAC de cookies de sesión
uvicorn	≥ 0.30.0	Servidor ASGI para ejecutar FastAPI
python-multipart	≥ 0.0.9	Procesamiento de archivos subidos (login crypto)
sqlalchemy	≥ 2.0.35	ORM para la capa de base de datos
psycopg[binary]	≥ 3.2.0	Driver nativo para PostgreSQL
pydantic-settings	≥ 2.5.2	Configuración tipada con variables de entorno
fpdf2	≥ 2.7.0	Generación de reportes en formato PDF

3. Instalación

3.1 Opción A: Instalación local (desarrollo)

1. Clonar el repositorio del proyecto.

```
git clone <URL_DEL_REPOSITORIO>
cd RetoCriptografia-Equipo2
```

2. Crear un entorno virtual de Python.

```
python -m venv venv
```

3. Activar el entorno virtual.

En **Windows** (PowerShell):

```
.\venv\Scripts\Activate.ps1
```

En **Windows** (CMD):

```
venv\Scripts\activate.bat
```

En **macOS / Linux**:


```
source venv/bin/activate
```

4. Instalar todas las dependencias del proyecto.

```
pip install -e .
```

Este comando lee el archivo `pyproject.toml` e instala automáticamente todas las bibliotecas listadas en la Tabla 5.

5. Ejecutar el servidor de desarrollo.

```
uvicorn app.main:app --reload
```

La bandera `-reload` habilita la recarga automática cuando se modifican archivos (solo para desarrollo).

6. Acceder a la aplicación. Abrir un navegador web y navegar a:

```
http://127.0.0.1:8000
```

Resultado esperado

La terminal muestra el mensaje `Uvicorn running on http://127.0.0.1:8000`. Al abrir esa URL en el navegador, aparece la página de inicio de sesión del sistema con el branding de Casa Monarca y el formulario de login.

3.2 Opción B: Instalación con Docker

1. Construir la imagen Docker.

```
docker build -t gestor-identidades .
```

2. Ejecutar el contenedor.

```
docker run -p 8000:8000 gestor-identidades
```

3. Acceder en `http://localhost:8000`.

El `Dockerfile` incluido usa Python 3.11 slim como imagen base y expone el puerto 8000.

3.3 Opción C: Despliegue en Render (producción)

El repositorio incluye un archivo `render.yaml` preconfigurado para despliegue con un clic en la plataforma Render, incluyendo una base de datos PostgreSQL administrada automáticamente.

Consideraciones importantes para producción

- **Obligatorio:** Definir la variable de entorno `SESSION_SECRET` con un valor aleatorio de al menos 32 bytes. Generar con: `openssl rand -hex 32`. Si no se cambia el valor predeterminado, el servidor rechaza arrancar.
- Establecer `SEED_DEMO_DATA=false` para no crear usuarios de demostración.
- Establecer `ENVIRONMENT=production` para activar las validaciones de seguridad.
- Usar PostgreSQL (`DATABASE_URL`) en lugar de SQLite para ambientes multiusuario.
- Definir `BOOTSTRAP_ADMIN_EMAIL` y `BOOTSTRAP_ADMIN_PASSWORD` para crear el administrador inicial de producción.

4. Inicio de la Aplicación

4.1 Cómo acceder

Una vez que el servidor está en ejecución, abrir el navegador web y navegar a la URL correspondiente:

- **Desarrollo local:** `http://127.0.0.1:8000`
- **Producción:** La URL asignada por el proveedor de hosting (ej. `https://mi-app.onrender.com`)

El sistema redirige automáticamente a la página de inicio de sesión (`/login`).

4.2 Inicio de sesión

La página de login se divide visualmente en dos paneles: a la izquierda se muestra el branding de Casa Monarca con la leyenda “Sistema de gestión de identidades y accesos”; a la derecha se presenta el formulario de autenticación con zonas de carga de archivos para el login criptográfico y campos para correo/contraseña.

4.2.1 Login por contraseña (Operativo / Voluntario)

1. Ingresar el correo electrónico o nombre de usuario en el campo “Correo o usuario”.
2. Ingresar la contraseña en el campo correspondiente.
3. Hacer clic en el botón “Entrar”.

Resultado esperado

Si las credenciales son correctas y la cuenta está activa, el sistema redirige al Portal del usuario donde se muestra la información de la cuenta, credenciales y sección de beneficiarios.

4.2.2 Login criptográfico (Administrador / Coordinador)

Los roles privilegiados requieren tres elementos para autenticarse:

1. **Subir el archivo de acceso** (`private_key.pem`): Arrastrar o hacer clic en la zona “Archivo de acceso” para seleccionar el archivo.

2. Subir el certificado de identidad (`certificate.pem`): Arrastrar o seleccionar el archivo en la zona “Certificado de identidad”.
3. Ingresar el correo electrónico en el campo “Correo o usuario”.
4. Ingresar la contraseña que protege el archivo de acceso.
5. Hacer clic en el botón “Entrar”.

¿Qué verifica el sistema internamente?

El servidor realiza las siguientes verificaciones criptográficas:

1. Descifra la llave privada usando la contraseña proporcionada.
2. Verifica que el certificado fue emitido por la autoridad correcta (autofirmado para Admin, firmado por el Admin para Coordinador).
3. Valida la vigencia, el número de serie y el email del certificado.
4. Genera un desafío criptográfico (*challenge*) único con timestamp.
5. Firma el desafío con la llave privada y verifica la firma con la llave pública del certificado.
6. Si todas las verificaciones pasan, crea la sesión.

4.2.3 Credenciales de demostración

Cuando `SEED_DEMO_DATA=true` (valor por defecto en desarrollo), el sistema crea automáticamente usuarios de prueba:

Cuadro 6: Credenciales de demostración disponibles

Usuario / Email	Contraseña	Rol	Método de login
admin	admin	Administrador	Bypass demo (solo contraseña)
operativo@demo.local	demo1234	Operativo	Contraseña
voluntario@demo.local	demo1234	Voluntario	Contraseña
coord.legal@demo.local	demo1234	Coordinador	Contraseña (sin cert)
coord.administracion@demo.local	demo1234	Coordinador	Contraseña (sin cert)
coord.psicosocial@demo.local	demo1234	Coordinador	Contraseña (sin cert)
coord.humanitario@demo.local	demo1234	Coordinador	Contraseña (sin cert)
coord.comunicacion@demo.local	demo1234	Coordinador	Contraseña (sin cert)

Importante

El acceso `admin / admin` es un `bypass` exclusivo para demostración. En producción (`SEED_DEMO_DATA=false`), se desactiva automáticamente y el administrador debe autenticarse con sus archivos criptográficos.

4.3 Configuración inicial

Al arrancar por primera vez, el sistema ejecuta automáticamente los siguientes pasos de inicialización:

1. Crea todas las tablas necesarias en la base de datos (users, roles, permissions, role_permissions, audit_logs, system_secrets, notifications, beneficiarios).
2. Genera los cuatro roles del sistema (Administrador, Coordinador, Operativo, Voluntario) con sus permisos específicos.
3. Si SEED_DEMO_DATA=true, crea los usuarios de demostración listados en la Tabla 6.
4. Si se definen BOOTSTRAP_ADMIN_EMAIL y BOOTSTRAP_ADMIN_PASSWORD, crea el administrador de producción con esas credenciales.
5. Genera la Autoridad Certificadora (CA) interna: un par de llaves RSA-2048 y un certificado raíz autofirmado válido por 10 años.
6. Crea y sincroniza el administrador espejo (cuenta de respaldo de emergencia).
7. Emite certificados criptográficos para los usuarios demo que requieren criptografía.

No se requiere configuración manual adicional para comenzar a usar el sistema en modo desarrollo.

5. Guía de Uso

Esta guía organiza las tareas principales del sistema por tipo de acción. Cada tarea incluye los pasos detallados, un ejemplo práctico y el resultado esperado.

5.1 Crear un nuevo usuario (Administrador)

Requisito: Sesión activa como Administrador.

Pasos:

1. Navegar al Panel de administración haciendo clic en "Panel de administración" dar clic en "Nuevo usuario." hacer clic directamente en la barra lateral en "Añadir usuario"
2. Localizar la sección "Crear usuario" o navegar a /admin/register.
3. Completar el formulario con los siguientes campos:
 - **Nombre completo:** Nombre y apellidos del nuevo usuario.
 - **Correo electrónico:** Dirección de email institucional (debe ser única en el sistema).
 - **Rol:** Seleccionar entre Administrador, Coordinador, Operativo o Voluntario.
 - **Fecha de expiración** (opcional): Fecha hasta la cual la cuenta será válida. Si se deja vacía, se asignan 365 días para roles criptográficos.
 - **Contraseña:** Contraseña inicial del usuario.
4. Hacer clic en el botón "Crear usuario".

Ejemplo: Crear al coordinador legal "María García" con email maria.garcia@casamonarca.org, rol "Coordinador" y contraseña "Cr1pt0Segura!".

Resultado esperado

El usuario se crea en estado "pending" (pendiente de activación). Si el rol seleccionado es Administrador o Coordinador, se generan automáticamente el certificado X.509 y la llave privada cifrada con la contraseña proporcionada. El administrador debe activar la cuenta antes de que el usuario pueda iniciar sesión.

Nota técnica

La contraseña proporcionada en este paso se usa para dos propósitos: (1) como contraseña de acceso si el rol no requiere criptografía, y (2) como contraseña para cifrar la llave privada (privatekey.pem) si el rol requiere criptografía.

Alta de usuario
Crea un nuevo usuario en el sistema.

Nombre completo: Diego Salinas

Correo electrónico: diegosalinas@gmail.com

Rol: Coordinador

Fecha de expiración: 20/05/2026 02:28

Contraseña inicial
Para roles con archivos de acceso, esta clave los protege al descargarlos

Crear usuario

Figura 1: Formulario de creación de usuario en el panel de administración

5.2 Activar un usuario pendiente (Administrador)

Requisito: Sesión activa como Administrador. Usuario objetivo en estado “pending”.

Pasos:

1. En el Panel de administración, localizar al usuario con estado “pending” en la lista.
2. Expandir la fila del usuario haciendo clic sobre ella.
3. Hacer clic en el botón “Activar”.
4. Si el usuario tiene rol criptográfico, se solicitará una contraseña para proteger el material criptográfico regenerado.

Ejemplo: Activar la cuenta de “María García” que fue creada en el paso anterior.

Resultado esperado

El estado del usuario cambia de “pending” a “active”. El usuario ya puede iniciar sesión. Se registra un evento de auditoría de tipo `user_status_updated` con resultado “success”.

Buscar por nombre o correo...

Todos los roles Todos los estados

Usuarios 16 usuarios

Maria Fernanda
mariafernanda@gmail.com

Voluntario pending sin vencimiento Acceso con contraseña Gestionar

CUENTA La cuenta existe pero todavía no puede entrar. Activar Revocar de emergencia	VIGENCIA dd/mm/yyyy --:-- Guardar vigencia	ROL Voluntario Guardar rol	ACCESO Acceso solo con usuario y contraseña.
---	---	---	--

5.3 Revocar un usuario (Administrador)

Requisito: Sesión activa como Administrador.

Pasos:

1. En el Panel de administración, localizar al usuario activo que se desea revocar.
2. Expandir su fila.
3. Hacer clic en el botón “Revocar”.
4. Confirmar la acción.

Ejemplo: Revocar el acceso de un voluntario que terminó su servicio.

Resultado esperado

El estado del usuario cambia a “revoked”. El usuario no puede iniciar sesión. Su certificado X.509, si tiene uno, deja de ser aceptado. Se genera el registro de auditoría correspondiente.

Buscar por nombre o correo...

Todos los roles Todos los estados

Usuarios 16 usuarios

Maria Fernanda
mariafernanda@gmail.com

Coordinador active 2027-05-15 08:42 Acceso con archivos Gestionar

CUENTA Acceso vigente Sin cambios pendientes Revocar de emergencia	VIGENCIA Fecha sellada en el certificado La vigencia de este usuario está fijada en su certificado de identidad y no puede modificarse directamente. Para extender el acceso, revocar la cuenta y generar nuevas credenciales desde la sección Credenciales.	ROL Coordinador Contraseña nueva (dásela al usuario) Guardar rol	CREDENCIALES ARCHIVO DE ACCESO ✓ Archivo de acceso entregado CERTIFICADO Ver certificado de identidad · Descargar certificado · Válido hasta 15/05/2027 Credenciales listas para entregar al usuario.
--	---	--	---

5.4 Emitir credenciales criptográficas (Administrador)

Requisito: Sesión activa como Administrador. Usuario objetivo con rol Admin o Coordinador.

Pasos:

1. En el Panel de administración, localizar al usuario.

2. Expandir su fila y localizar la sección “Credencial”.
3. Ingresar una contraseña que protegerá el archivo de acceso del usuario.
4. Hacer clic en “Emitir credencial” (primera vez) o “Reemitir” (si ya existían credenciales previas).

Ejemplo: Emitir credenciales para “María García” (Coordinador Legal) con la contraseña “AccesoLegal2023”.

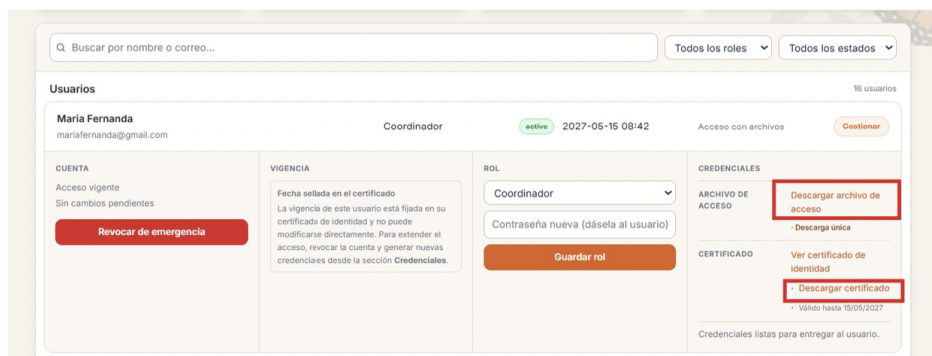
Resultado esperado

Se generan los siguientes archivos para el usuario:

- `certificate.pem` — Certificado digital X.509 firmado por el administrador activo. Es público y puede descargarse múltiples veces.
- `private_key.pem` — Llave privada RSA-2048 cifrada con AES-256 usando la contraseña proporcionada. Descarga única: se elimina del servidor tras la primera descarga.

Descarga única del archivo de acceso

El archivo `private_key.pem` solo puede descargarse una sola vez. Después de la primera descarga, el servidor lo elimina permanentemente de la base de datos por seguridad. Si se pierde el archivo, el administrador debe reemitir las credenciales completas, lo que invalida automáticamente las anteriores.



5.5 Descargar archivos criptográficos

5.5.1 Descargar el archivo de acceso (`private_key.pem`)

Pasos:

1. El administrador navega al usuario en el dashboard, o el propio usuario navega a su portal (`/portal`).
2. En la sección “Mis credenciales” (portal) o en la fila del usuario (dashboard), hacer clic en “Descargar archivo de acceso”.
3. El navegador descarga automáticamente el archivo.

Advertencia crítica

Este enlace funciona una sola vez. Después de hacer clic, el estado cambia a “Archivo de acceso entregado” y la descarga no puede repetirse. Guardar el archivo en un lugar seguro y protegido.

5.5.2 Descargar el certificado (certificate.pem)

Pasos:

1. Navegar al portal del usuario o al detalle del usuario en el dashboard.
2. Hacer clic en “Descargar certificado” o “Ver certificado de identidad”.
3. El navegador descarga el archivo `certificate.pem`.

Nota

El certificado es un documento público. Contiene solo la llave pública y la identidad del usuario. Puede descargarse múltiples veces sin restricción. La información sensible es únicamente el archivo de acceso (llave privada).



5.6 Registrar

un

beneficiario

Requisito: Sesión activa con cualquier rol.

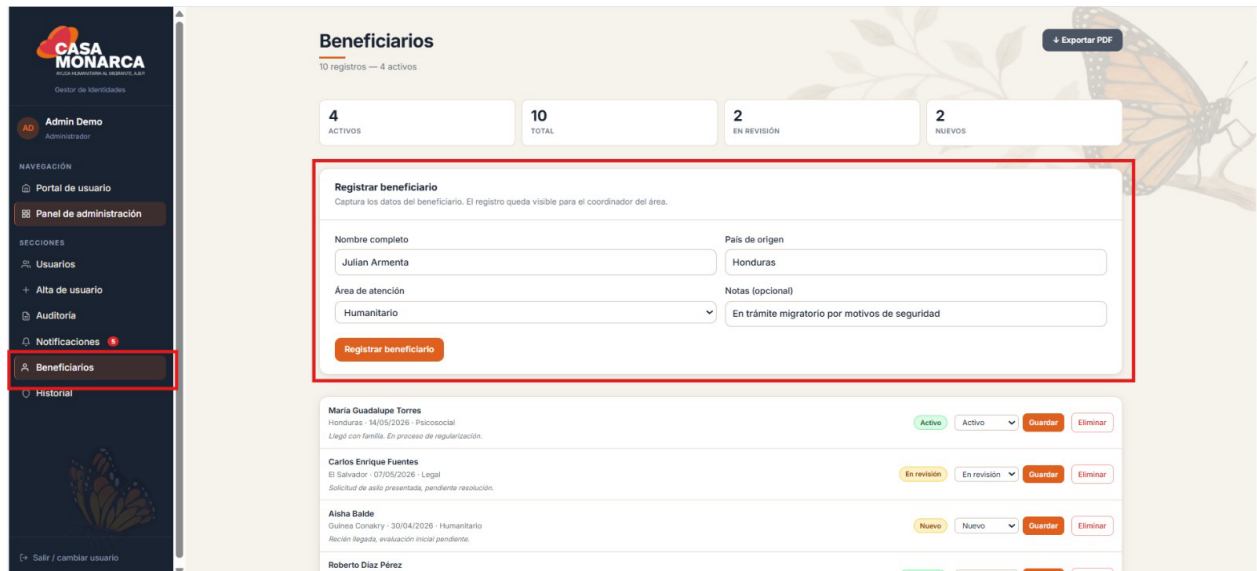
Pasos:

1. En el Portal (/portal), navegar a la sección “Beneficiarios”.
2. Completar el formulario de registro:
 - **Nombre completo:** Nombre de la persona migrante atendida.
 - **País de origen:** País de procedencia de la persona.
 - **Área:** Seleccionar el área de atención: Administración, Legal, Psicosocial, Humanitario o Comunicación.
 - **Notas** (opcional): Información adicional relevante para el caso.
3. Hacer clic en “Registrar beneficiario”.

Ejemplo: Registrar a “Juan Pérez López”, de Honduras, en el área Legal, con nota “Requiere asesoría para solicitud de refugio”.

Resultado esperado

El beneficiario se registra con estado “nuevo” y aparece en la lista. Los Coordinadores y Administradores pueden actualizar su estado conforme avanza la atención, siguiendo el flujo: nuevo → en_revisión → canalizado → activo.



5.7 Cambiar el estado de un beneficiario (Coordinador / Administrador)

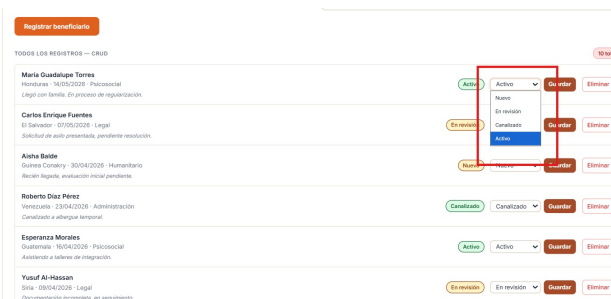
Pasos:

1. En la sección “Beneficiarios” del portal, localizar al beneficiario en la tabla.
2. Seleccionar el nuevo estado en el menú desplegable junto al registro.
3. Hacer clic en “Actualizar”.

Ejemplo: Cambiar el estado de “Juan Pérez López” de “nuevo” a “en_revisión” después de la primera entrevista.

Resultado esperado

El estado del beneficiario se actualiza en la base de datos y se refleja inmediatamente en la tabla.



5.8 Generar reportes en PDF

El sistema permite exportar tres tipos de reportes, cada uno con un hash SHA-256 de integridad:

Cuadro 7: Tipos de reporte disponibles para exportación

Reporte	Ruta	Acceso	Contenido
Usuarios	/ui/users/export.pdf	Admin	Nombre, email, rol, estado, fecha de creación
Auditoría	/ui/audit-logs/export.pdf	Admin	Fecha, tipo, acción, resultado, IP
Beneficiarios	/ui/beneficiarios/export.pdf	Admin/Coord	Nombre, país, área, estado

Pasos:

1. Navegar a la sección correspondiente (Dashboard para usuarios/auditoría, Portal para beneficiarios).
2. Hacer clic en el botón “Exportar PDF” o “Descargar PDF”.
3. El navegador descarga automáticamente el archivo PDF.

Integridad del reporte

Cada reporte incluye en el pie de página un hash SHA-256 calculado sobre los datos del reporte. Si alguien altera el contenido después de la generación, recalculer el hash sobre los datos producirá un valor diferente, permitiendo detectar la manipulación.

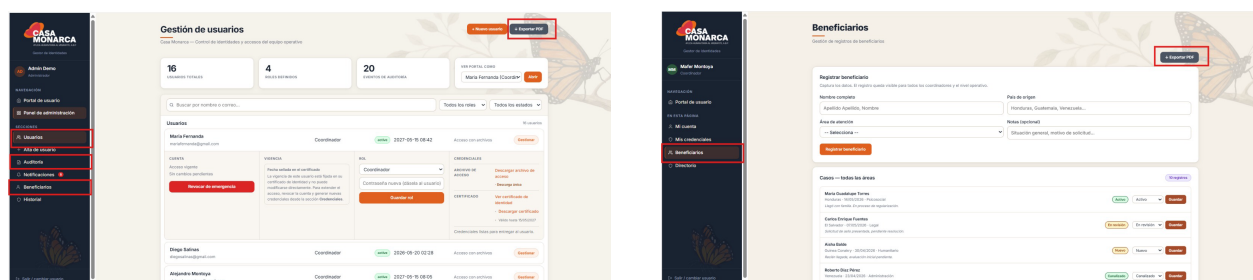


Figura 2: Vista de reportes

5.9 Cambiar el rol de un usuario (Administrador)

Pasos:

1. En el Panel de administración, localizar al usuario.
2. Expandir su fila y buscar el control “Cambiar rol”.
3. Seleccionar el nuevo rol del menú desplegable.
4. Si el nuevo rol requiere criptografía (Admin o Coordinador), ingresar una contraseña para proteger los nuevos archivos.
5. Confirmar el cambio.

Ejemplo: Promover a “Omar Operativo” de rol Operativo a Coordinador.

Resultado esperado

El rol se actualiza. Si el cambio implica pasar a un rol criptográfico, se emiten automáticamente nuevos archivos `private_key.pem` y `certificate.pem`.

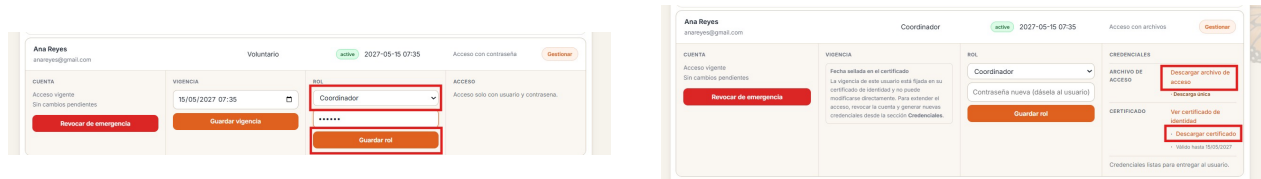


Figura 3: Cambio de rol de usuario

5.10 Desbloquear una cuenta bloqueada (Administrador)

El sistema bloquea automáticamente las cuentas después de 10 intentos fallidos consecutivos de inicio de sesión. El bloqueo es indefinido y requiere intervención del administrador.

Pasos:

1. En el Panel de administración, localizar al usuario bloqueado.
2. Hacer clic en el botón “Desbloquear”.

Ejemplo: Desbloquear la cuenta de “coord.legal@demo.local” después de que el usuario olvidó su contraseña y excedió los 10 intentos.

Resultado esperado

El contador de intentos fallidos se reinicia a cero. El bloqueo se elimina. El usuario puede volver a intentar iniciar sesión normalmente.

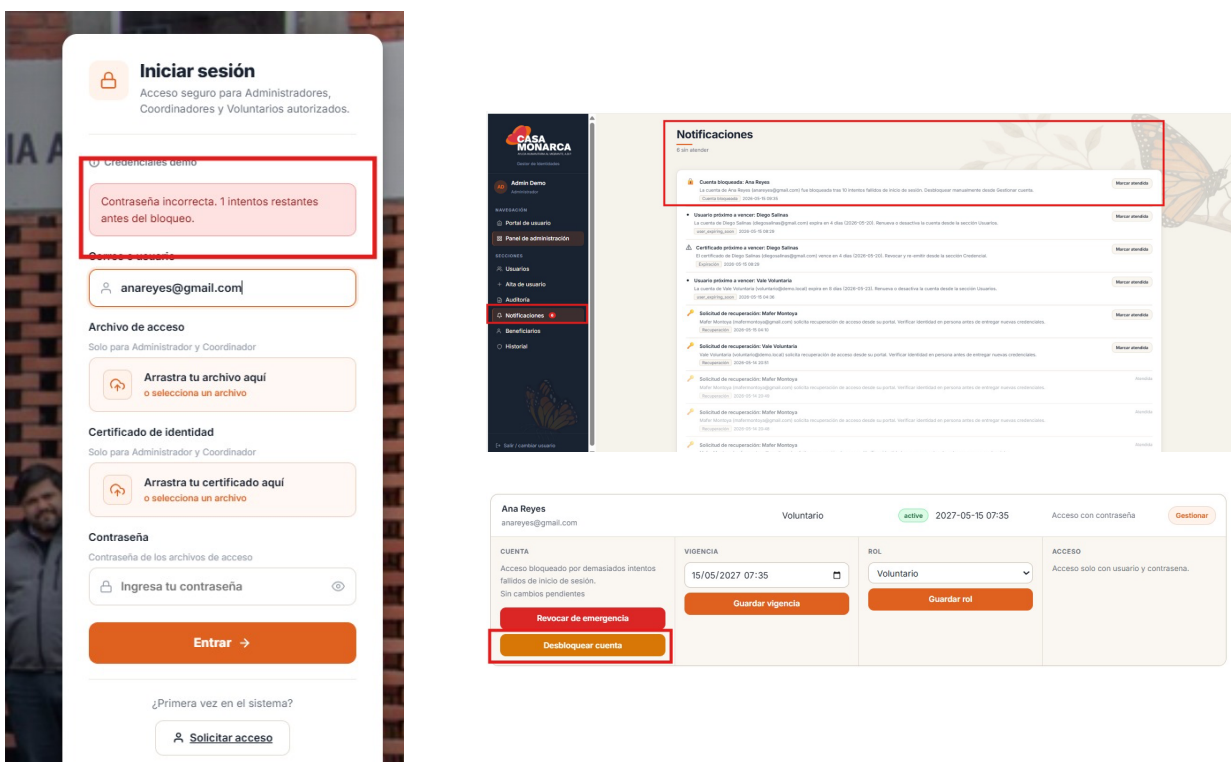


Figura 4: Activación de cuenta bloqueada

5.11 Activar el administrador espejo (recuperación de emergencia)

Este procedimiento se usa exclusivamente en emergencias, cuando el administrador principal no puede acceder al sistema (pérdida de credenciales, incapacidad, etc.).

Pasos:

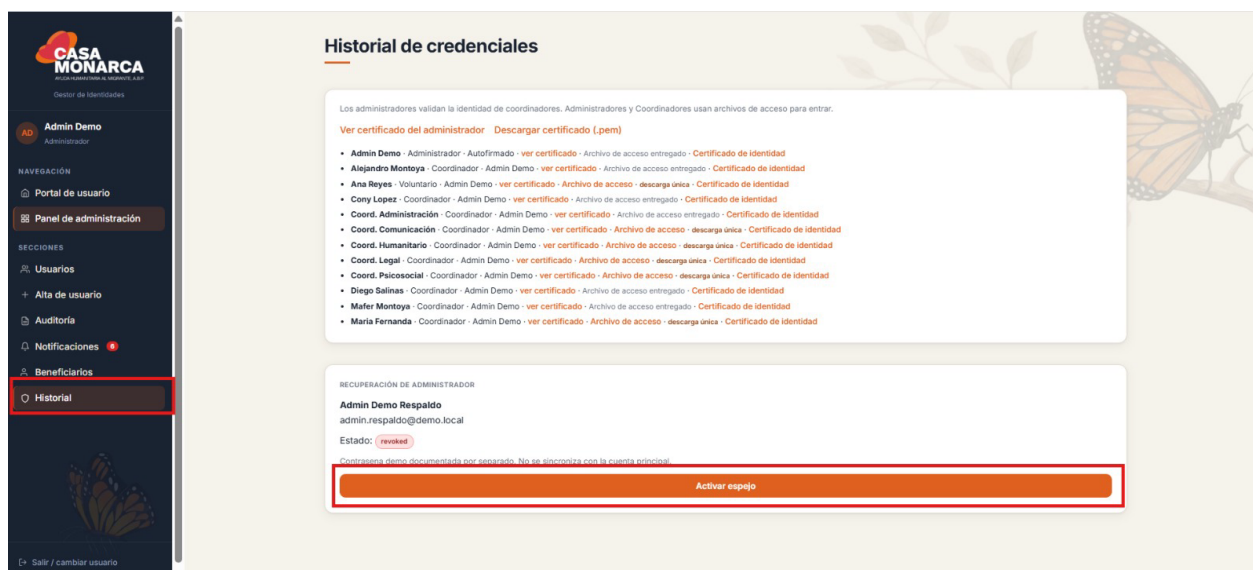
1. Iniciar sesión como el administrador principal.
2. En el Panel de administración, localizar la sección “Recuperación”.
3. Hacer clic en “Activar administrador espejo”.
4. Confirmar la acción.

Resultado esperado

- El administrador principal queda revocado permanentemente.
- El administrador espejo se activa con sus propias credenciales independientes.
- Se registra el evento `admin_recovery_activated` en la auditoría.

Procedimiento irreversible

Una vez activado el espejo, el administrador principal queda permanentemente revocado y sin contraseña. El nuevo administrador activo debe emitir un nuevo respaldo para garantizar la continuidad futura.



5.12 Auto-registro de voluntarios

Los voluntarios y pasantes pueden solicitar acceso al sistema sin intervención directa del administrador.

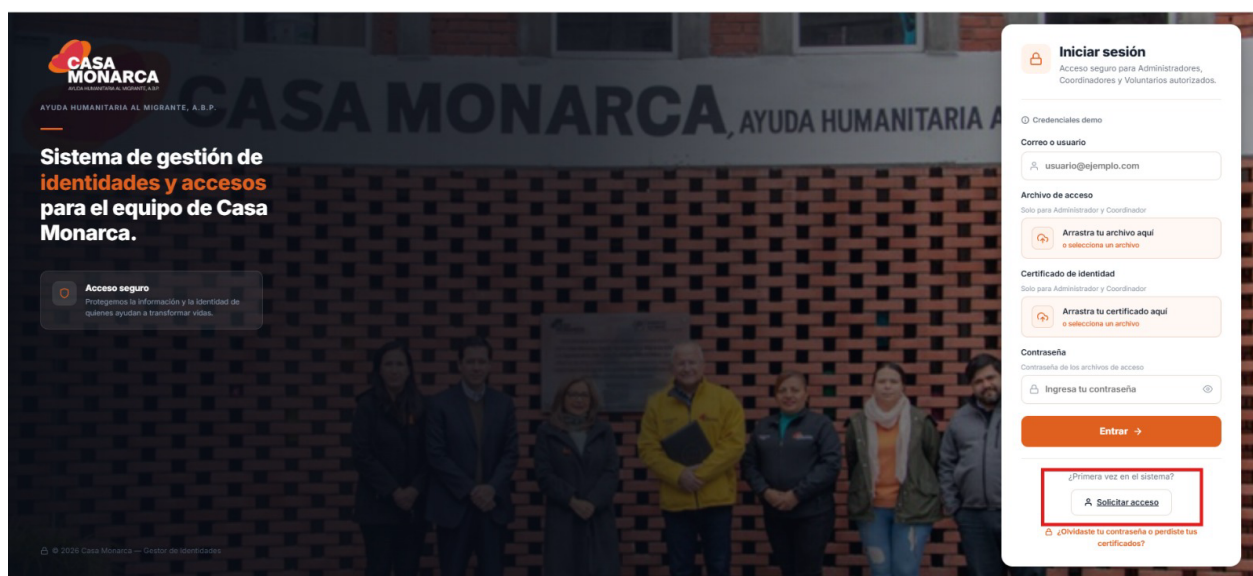
Pasos:

1. Desde la página de inicio de sesión, hacer clic en “Solicitar acceso”.
2. Completar el formulario:
 - Nombre completo.
 - Correo electrónico.
 - Contraseña.
 - Confirmar contraseña.
3. Hacer clic en “Registrarse”.

Ejemplo: La voluntaria “Valentina López” se registra con `valentina@gmail.com`.

Resultado esperado

Se crea una cuenta con rol Voluntario en estado “pending”. El usuario **no puede iniciar sesión** hasta que un administrador active su cuenta desde el panel de administración.



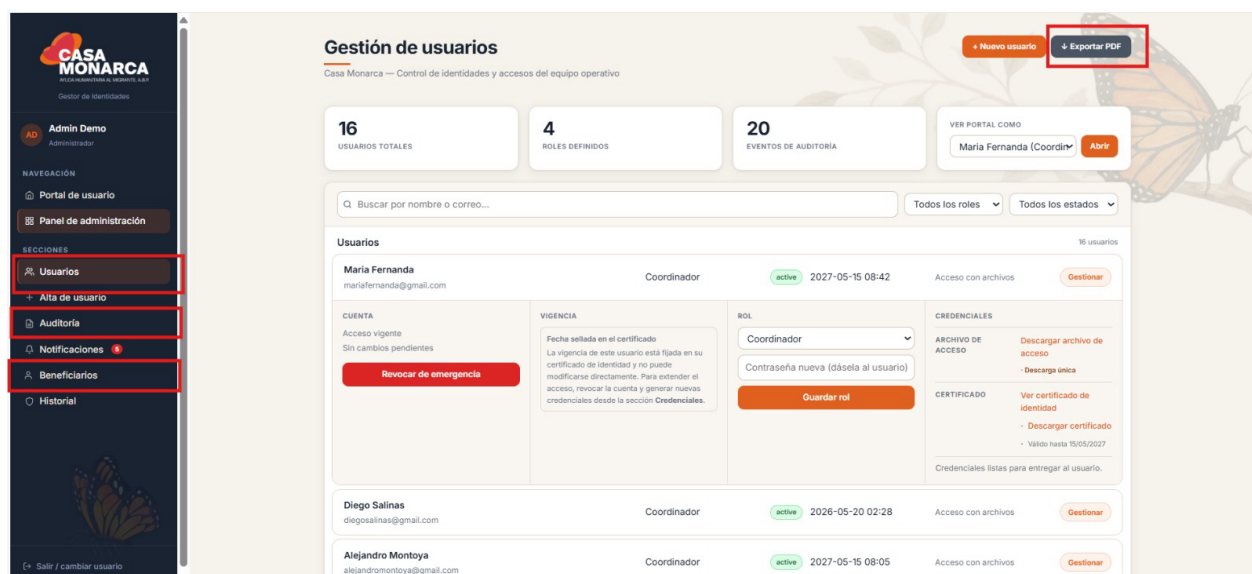
5.13 Consultar la auditoría (Administrador)

Pasos:

1. En el Panel de administración, navegar a la sección “Auditoría”.
2. Revisar la tabla con los últimos eventos del sistema:
 - **Fecha:** Timestamp del evento.
 - **Tipo:** login_password, login_crypto, certificate_issued, user_status_updated, access_denied, etc.
 - **Acción:** create, activate, revoke, login, etc.
 - **Resultado:** success o failure.
 - **IP:** Dirección IP del cliente.
 - **User-Agent:** Identificador del navegador utilizado.
3. Para exportar, hacer clic en “Exportar PDF”.

Resultado esperado

Se muestra la tabla con los últimos 50 eventos. Al exportar, se descarga un PDF con todos los eventos visibles y un hash SHA-256 de integridad.



5.14 Ver certificados digitales

5.14.1 Certificado de la autoridad firmante (CA)

Pasos:

1. Desde el Panel de administración, hacer clic en “Ver certificado de la CA” o navegar a `/ui/ca/certificate/view`.
2. Se muestra una página con los detalles del certificado raíz del sistema:

- **Sujeto / Emisor:** “Casa Monarca Internal CA” (autofirmado).
- **Serie:** Número hexadecimal único.
- **Vigencia:** 10 años desde la creación.
- **Huella SHA-256:** Fingerprint criptográfico del certificado.
- **PEM:** Certificado completo en formato PEM (expandible).

5.14.2 Certificado de un usuario

Pasos:

1. Desde el Panel de administración, expandir la fila del usuario con certificado.
2. Hacer clic en “Ver certificado de identidad”.
3. Se muestra la misma vista con los datos específicos del certificado: sujeto (nombre del usuario), emisor (administrador firmante), SAN (email del usuario), vigencia y fingerprint.



Figura 5: Descarga de certificado

6. Solución de Problemas

6.1 Errores comunes

Cuadro 8: Errores comunes y sus soluciones

Error / Síntoma	Causa probable	Solución
"No se pudo abrir private_key.pem con esa contraseña"	Contraseña incorrecta para descifrar la llave privada	Verificar que se usa la contraseña exacta proporcionada por el administrador al emitir las credenciales. Distingue mayúsculas y minúsculas.
"La cuenta no está activa: pending"	La cuenta fue creada pero no ha sido activada por un admin	Contactar al administrador para que active la cuenta desde el panel de administración.
"Cuenta bloqueada por demasiados intentos fallidos"	Se superaron los 10 intentos de login permitidos	Contactar al administrador para que desbloquee la cuenta. El bloqueo es indefinido.
"El certificado está fuera de vigencia"	El certificado X.509 expiró (fecha not_after superada)	El administrador debe reemitir las credenciales del usuario con una nueva fecha de vigencia.
"Este usuario requiere autenticación con private_key.pem y certificate.pem"	Se intenta hacer login solo con contraseña para un rol que requiere crypto	Usar la autenticación criptográfica: subir los archivos .pem además de la contraseña.
"La llave privada ya fue entregada"	Se intenta descargar private_key.pem por segunda vez	El administrador debe reemitir las credenciales. La llave anterior fue eliminada del servidor.

Error / Síntoma	Causa probable	Solución
“SESSION_SECRET debe definirse con un valor seguro”	Servidor en modo producción sin cambiar el secreto predeterminado	Definir la variable SESSION_SECRET con: <code>openssl rand -hex 32</code> .
ModuleNotFoundError al iniciar	Las dependencias no están instaladas	Activar el entorno virtual y ejecutar <code>pip install -e .</code>
“El certificado no corresponde al usuario registrado”	Se subió un certificado de otro usuario o uno antiguo	Descargar el certificado correcto desde el portal del usuario.
Base de datos vacía al iniciar	Primera ejecución o BD eliminada	Normal. El sistema crea tablas y datos demo automáticamente.

6.2 Qué hacer si algo falla

1. **Revisar la terminal:** Los errores del servidor se imprimen en la consola donde corre `uvicorn`. Buscar el mensaje específico.
2. **Verificar la URL:** Asegurarse de usar `http://127.0.0.1:8000` (local) o la URL correcta de producción.
3. **Limpiar cookies:** Si hay problemas de sesión, borrar las cookies del sitio en el navegador.
4. **Reiniciar el servidor:** Detener con `Ctrl+C` y ejecutar de nuevo `uvicorn app.main:app --reload`.
5. **Recrear la BD:** Eliminar `identity_demo.db` y reiniciar. Se crea una base de datos limpia con todos los datos demo.
6. **Verificar archivos:** Confirmar que `private_key.pem` y `certificate.pem` son los correctos y no están corruptos.

6.3 Contacto de soporte

- **Equipo:** Equipo 2 — Criptografía
- **Institución:** Tecnológico de Monterrey
- **Curso:** Criptografía — 6to Semestre
- **Repositorio:** Consultar el archivo `README.md` del proyecto para la URL del repositorio y documentación adicional.

7. Preguntas Frecuentes (FAQ)

P1. ¿Qué hago si perdí mi archivo de acceso (`private_key.pem`)?

Contactar al administrador del sistema. El administrador reemitirá las credenciales desde el panel de administración, generando un nuevo par de archivos (`private_key.pem` y `certificate.pem`). Los archivos anteriores quedan automáticamente invalidados al cambiar el número de serie del certificado.

P2. ¿Puedo usar mi `private_key.pem` en más de un dispositivo?

Sí. Una vez descargado, el archivo puede copiarse a cualquier dispositivo. Sin embargo, debe protegerse con el mismo cuidado que una contraseña: cualquier persona con el archivo **y** la contraseña que lo descifra puede suplantar la identidad del usuario.

P3. ¿Por qué el administrador usa certificados en lugar de una contraseña simple?

Porque los certificados proporcionan autenticación de dos factores: algo que *tienes* (el archivo) y algo que *sabes* (la contraseña). Una contraseña sola puede ser adivinada, robada o filtrada; con certificados, el atacante necesita también poseer el archivo físico. Además, el certificado permite verificar criptográficamente que fue emitido por una autoridad legítima.

P4. ¿Qué es el “administrador espejo” y cuándo debo usarlo?

Es una copia de seguridad del administrador principal, mantenida automáticamente por el sistema en estado “revocado”. Solo se usa en emergencias: si el admin principal pierde sus credenciales o no puede acceder, se activa el espejo para recuperar el control. Las credenciales del espejo deben guardarse en un lugar seguro y separado (por ejemplo, un sobre sellado).

P5. ¿Qué pasa cuando mi cuenta expira?

El estado cambia automáticamente a “expired” y no es posible iniciar sesión. El administrador puede renovar la cuenta actualizando la fecha de expiración y, si aplica, reemitiendo las credenciales criptográficas con la nueva vigencia.

P6. ¿Cómo puedo verificar que un reporte PDF no fue alterado?

Cada PDF incluye un hash SHA-256 en el pie de página, calculado sobre los datos tabulados del reporte. Para verificar: extraer los datos del PDF, recalcular el hash SHA-256 y comparar con el impreso. Si no coinciden, el contenido fue modificado.

P7. ¿Puedo registrarme sin que un administrador me cree la cuenta?

Sí, pero solo como Voluntario. Desde la página de login, seleccionar “Solicitar acceso” y completar el formulario. La cuenta queda en estado “pending” hasta que un administrador la active.

P8. ¿Qué base de datos usa el sistema?

En desarrollo usa **SQLite** (archivo `identity_demo.db`). En producción se recomienda **PostgreSQL** configurando la variable `DATABASE_URL`.

P9. ¿Es seguro para producción real?

El sistema implementa buenas prácticas (PBKDF2, RSA-2048, cookies firmadas, X.509). Para producción real se recomienda adicionalmente: HTTPS obligatorio, mayor número de iteraciones de PBKDF2, un HSM para la CA, rate limiting por IP, y un servicio de secretos externo (Vault, AWS KMS).

P10. ¿Cuántos intentos de login tengo antes del bloqueo?

10 intentos. Después del décimo intento fallido consecutivo, la cuenta se bloquea indefinidamente. Solo un administrador puede desbloquearla.

8. Referencias

1. FastAPI Documentation. Disponible en: <https://fastapi.tiangolo.com/>. Framework web utilizado para el desarrollo del servidor.
2. Python Cryptography Library. Disponible en: <https://cryptography.io/>. Biblioteca para operaciones criptográficas: RSA, X.509, PBKDF2, firmas digitales.

3. RFC 5280 — Internet X.509 Public Key Infrastructure Certificate and CRL Profile. IETF. Estándar de certificados digitales X.509.
4. RFC 8017 — PKCS #1: RSA Cryptography Specifications Version 2.2. IETF. Esquemas de padding PKCS#1 v1.5 y PSS.
5. RFC 2898 — PKCS #5: Password-Based Cryptography Specification Version 2.0. IETF. Especificación de PBKDF2.
6. OWASP Password Storage Cheat Sheet. Disponible en: https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html.
7. NIST SP 800-63B — Digital Identity Guidelines: Authentication and Lifecycle Management. NIST.
8. SQLAlchemy 2.0 Documentation. Disponible en: <https://docs.sqlalchemy.org/>.
9. itsdangerous Documentation. Disponible en: <https://itsdangerous.palletsprojects.com/>.
10. Docker Documentation. Disponible en: <https://docs.docker.com/>.